

Report Generation

Revision

Version 3
2/23/26 7:01 PM

Author

Charles Wilson

Abstract

This document describes the general methodology for the generation of reports called out by various activities within the AVCDL [\[1\]](#).

Audience

The audience of this document are the cybersecurity SMEs responsible for the generation of reports to be stored within the document management system (DMS) as documents of record.

Note: This document is not subject to certification body review.

License

This work was created by **Torc Robotics** and is licensed under the **Creative Commons Attribution-Share Alike (CC BY-SA-4.0)** License.

<https://creativecommons.org/licenses/by/4.0/legalcode>

Introduction

Within the AVCDL many processes have activities which generate reports intended to be used as documents of record stored in the DMS. The audience of these reports is not generally the development team, but rather auditors concerned with the appropriateness of actions taken based on the various cybersecurity activities performed. In all cases where reports are generated, the core information used to create them is destined for downstream handling within the threat prioritization process [\[8\]](#) and eventually the issue tracking system.

The distinction here of the target audience is important because each will have different concerns. Auditors are more concerned with the overall handling of traceability (long time horizon), whereas developers are focused on the specific issues (short time horizon). As such, the focus of the generated report is human-readability.

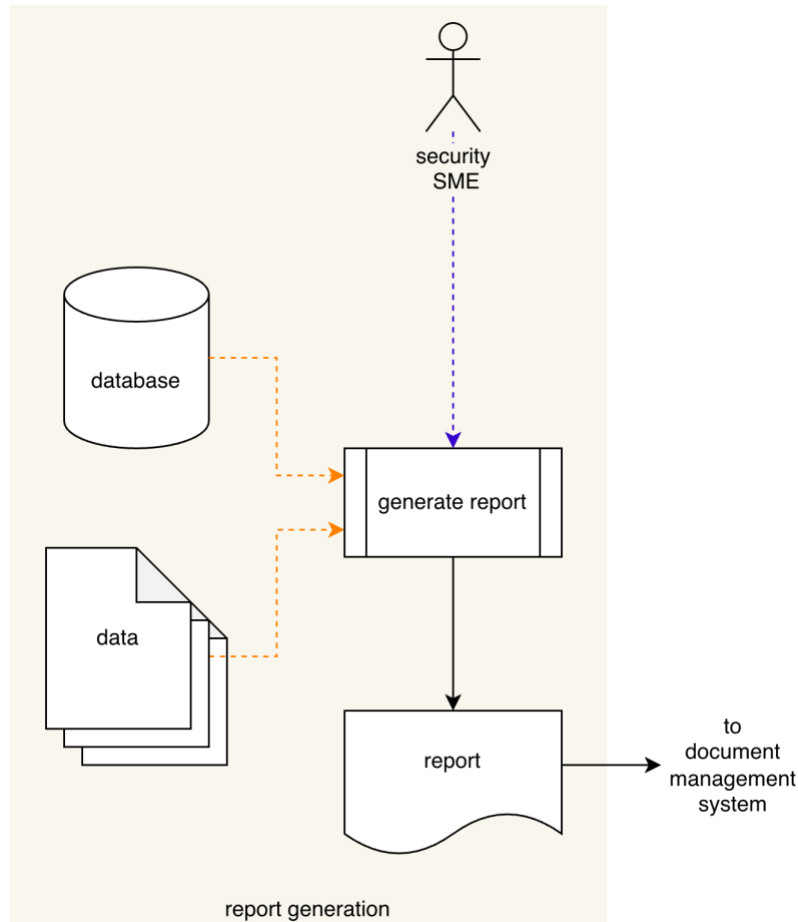
Note on the use of URIs

Within the context of this document, when a URI is specified the expectation is that it provide an identifier capable of locating the resource in both space and time. This is to say that there should be no ambiguity as to which of a possible number of revisions of the resource is being referenced.

By way of example, it is insufficient to provide a link to a code branch as that is a moving target. A commit hash, tag, or release would be required in order to establish an accurate point in time.

Report Generation Activity

The general workflow diagram for the **report generation** activity is shown below.



The various input sources (**Database** or unstructured **Data** files) are organized and formatted into a human-readable form. This may be done either in an automated manner using a **Generate Report** process or may be performed manually by the **Security SME**. The **Report** is delivered to the **DMS**.

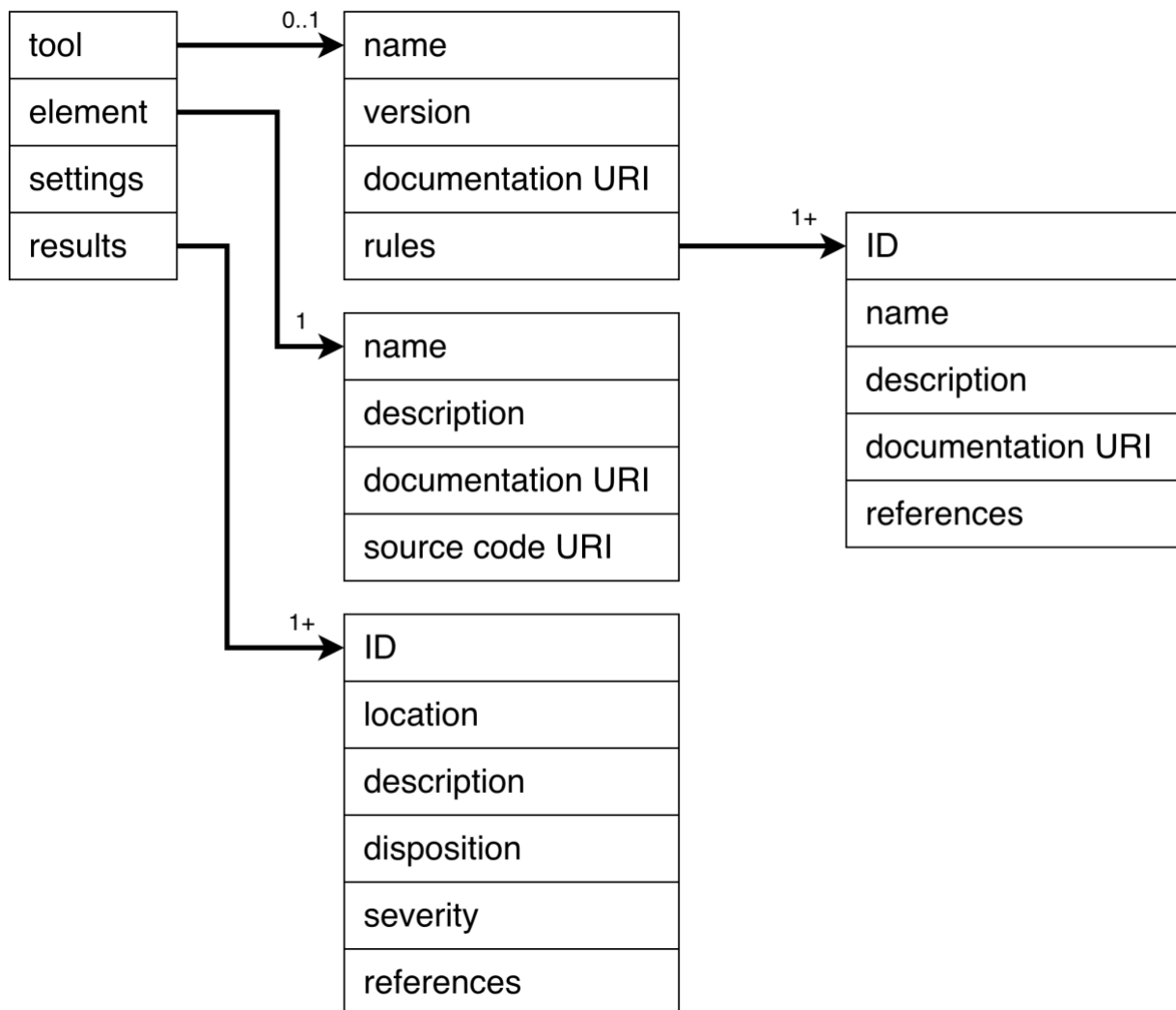
Note: The recommended form of the **Identified Issues** artifact is JSON-encoded Static Analysis Results Interchange Format (**SARIF**). This document assumes SARIF version 2.1.0 [\[7\]](#) or later.

Report Composition

Every report is presumed to contain a preamble of report type (**static analysis** ^[2], **dynamic analysis** ^[3], ...), preparer (security SME / automation), and date of generation.

Note: Organizational classifications (**internal use only**, **company confidential**, ...) may be included as appropriate.

The core of the report is comprised of one or more run, which are composed as follows:



Note: This composition will work for the majority of cybersecurity activity reports. Penetration testing requires a more elaborate report. This is covered in the **Penetration Testing Report** ^[4].

Tool

This section covers the tool used to perform the activity. This is critical from the standpoint of reproducibility of results.

Note: When the activity does not involve software tooling, this should be noted.

Note: Aside from the rules, all information regarding the tool should have been recorded as covered in the **List of Approved Tools and Components** ^[5] secondary document. A list of information that may be captured for the tool is described in the **Open Source Use Tracking** section of the **Understanding Open Source in an AVCDL Context** ^[6] elaboration document.

Name

Software name

Version

This should be as precise as possible to avoid issues of reproducibility.

Note: When required the release date of the tool should be included.

Documentation URI

Location of the documentation corresponding to the specific version of the tool.

Note: It is recommended that the organization keep archive copies of tool documentation in order to avoid legacy software issues.

Rules

This is the list of rules applied to the element by the tool.

Rules

This section covers the rules applied by the tool to the element under consideration.

ID

This may be either an explicit unique identifier specified by the tool, or a synthetic, but still unique identifier established by the organization. In the case of rules directly represented by tool settings (for example: compiler warnings), the settings may be used when practical.

Note: When using synthetic identifiers, keep in mind that they may be used as fields within various tracking systems and may require additional handling when referencing them within selection logic such as scripting languages.

Name

Name of the rule

Description

Depending upon the type of analysis and tool used, there may be both short and long forms of the rule description available.

Documentation URI

Location of the documentation corresponding to the rule.

Note: It may be the case that all rules share a common documentation location. However, when there is more granularity available, make use of it.

References

References to associated taxonomy entries, such as Common Weakness Enumeration (CWE).

Element

This section covers the element under consideration.

Name

Element name

Description

The element's description should provide sufficient context in order to identify the element within the larger system.

Note: Diagrams should be included when appropriate.

Documentation URI

Location of the documentation of the element under consideration.

Source Code URI

Location of the source code of the element under consideration.

Results

This section covers the results of the analysis.

ID

Unique identifier of the result

Location

The location within the context of the type of analysis. This may be a location within a diagram in the case of threat modeling or within a source file in the case of static or dynamic analysis.

Description

The description should contain a reference to the rule violated and sufficient information to verify the issue.

Note: Diagrams should be included when appropriate.

Disposition (optional)

The disposition of the issue as assigned during triage.

Severity (optional)

The initial severity of the issue as assigned during triage.

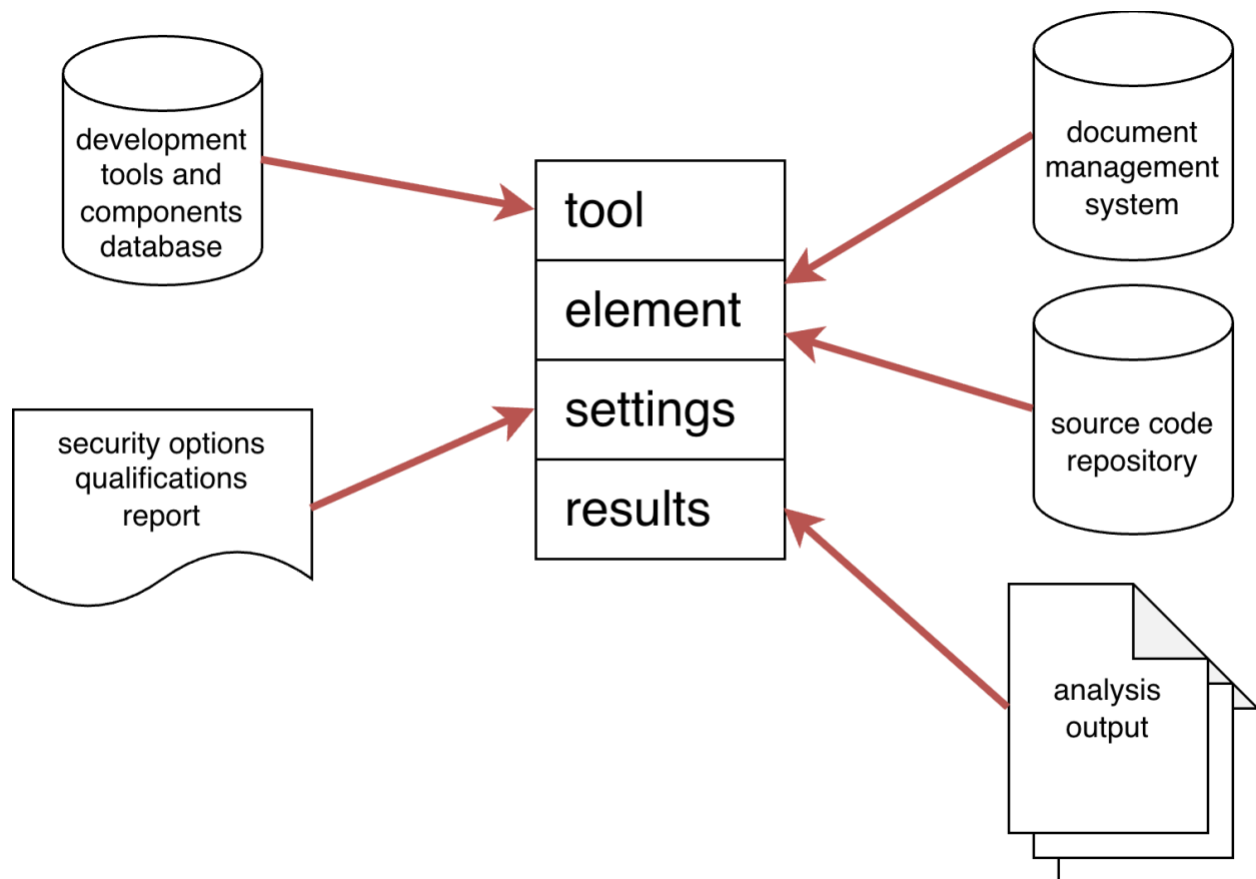
References (optional)

References to specific associated taxonomy entries.

Input Sources

By the time that a cybersecurity process has reached the stage where a report is warranted, multiple sources have been either utilized or referenced. Fewer for ones like secure settings. More for explicit analysis processes like static and dynamic analysis.

The following diagram shows the general report input sources:



Note: It is recognized that not every organization will have reached a level of maturity where databases are used for aggregating various common information. This is one of the reasons why the AVCDL provides and discusses data handling via workbook templates as they are readily available, do not require a particular level of organizational maturity, and are directly abstractable into database schemas.

Tool

The authoritative source for tools will be the development tools and components database described in the **List of Approved Tools and Components** secondary document. Since only approved tools should be used in the creation of safety-critical, cyber-physical systems, all tools are assumed to have been ingested through this process.

Element

Information regarding any element of the system should be documented in either the DMS or source code repository.

Settings

The tool settings are sourced from the **security options qualifications report** generated using the **Secure Settings Document** [\[7\]](#) secondary document process.

Note: Not every organization will have reached a level of maturity where databases are used for aggregating various common information. This is one of the reasons why the AVCDL provides and discusses data handling via workbook templates as they are readily available, do not require a particular level of organizational maturity, and are directly abstractable into database schemas for those organizations which do have the maturity to utilize databases.

Results

The results are sources from the analysis process itself. It is shown above as a collection. Depending on the analysis methodology, the results may be consolidated.

Report Assembly

There are two variants of the generated report. The first simply enumerates the results. The second groups the results by disposition and severity. The second case is used for reports coming out of triage activities. Since the first case is trivial, only the second will be discussed.

When comparing the information specified in the previous section to the information accumulated leading up to the point where the report is necessitated, it becomes clear why it is insufficient to simply collect the various source documents / data and present that in place of a generated human-readable report.

Mechanism

Assembly of the report may be automated. This is recommended. If SARIF and/or databases have been used to embody the various input sources, transformation of these materials is straightforward. Additionally, because of the generic structure specified, any automation will be transferable throughout the lifecycle's processes.

When generated manually, it is recommended that the material be embodied into a format which can be rendered to a PDF as this is the preferred format for documents of record.

Note: Python libraries are available for ingesting JSON-encoded SARIF and also generating PDFs.

Content

Preamble

The report preamble should contain the following information:

- Title (embeds report type)
- Author ("generated" may be used if the report was created via automation)
- Date
- Revision (where appropriate)
- Consolidated list of references

Note: The specific composition of the report preamble section is established by the organization.

Core

When organizing the results ensure that clear section headings be used. Additionally, triaged issues should be presented in the following order (review, repair, and reject).

Individual results should use reference rule IDs, rather than restating them.

References

1. **AVCDL** (AVCDL primary document)
2. **Static Analysis Report** (AVCDL secondary document)
3. **Dynamic Analysis Report** (AVCDL secondary document)
4. **Penetration Testing Report** (AVCDL secondary document)
5. **List of Approved Tools and Components** (AVCDL secondary document)
6. **Understanding Open Source in an AVCDL Context** (AVCDL elaboration document)
7. **Static Analysis Results Interchange Format (SARIF) Version 2.1.0**
<https://docs.oasis-open.org/sarif/sarif/v2.1.0/os/sarif-v2.1.0-os.pdf>
8. **Threat Prioritization Plan** (AVCDL secondary document)